

安全测试清单

1. 测试目标

本系统当前采用“JWT 工具类 + Controller 手动鉴权”的方式进行权限控制，尚未使用统一 JWT 拦截器或 Spring Security 全局过滤机制。因此需要重点测试是否存在以下安全风险：

- 1. 未登录用户直接访问管理端接口。
- 2. 普通用户通过 API 访问管理员接口。
- 3. 伪造、缺失、过期或错误 Token 后接口仍返回敏感数据。
- 4. 某些 Controller 忘记手动鉴权，导致接口越权访问。
- 5. 前端路由拦截有效，但后端接口没有真正校验权限。
- 6. 通过服务器 API 获取知识库、咨询记录、情绪日志、用户信息等后台数据。

测试采用黑盒测试、白盒测试和灰盒测试相结合的方式进行。

2. 测试账号准备

角色	账号	说明	结果
未登录用户	无	不携带 Token 请求接口	☐ 通过 ☐ 不通过
普通用户	普通用户账号	只能访问用户端功能	☐ 通过 ☐ 不通过
管理员	管理员账号	可访问后台管理接口	☐ 通过 ☐ 不通过
无效 Token	手动构造	随机字符串或篡改后的 Token	☐ 通过 ☐ 不通过
过期 Token	旧 Token	已过期或退出后的 Token	☐ 通过 ☐ 不通过

3. 黑盒测试清单

黑盒测试不查看代码，只通过浏览器、Postman、Apifox、curl 或浏览器 Network 面板验证接口是否存在越权访问。

3.1 未登录访问后台页面

编号	测试项	操作步骤	预期结果	结果
B-01	未登录访问后台首页	清空浏览器 localStorage，访问 <code>/user/dashboard</code>	跳转登录页	☐ 通过 ☐ 不通过
B-02	未登录访问知识管理页	清空登录状态，访问 <code>/user/knowledge</code>	跳转登录页	☐ 通过 ☐ 不通过
B-03	未登录访问咨询记录页	清空登录状态，访问 <code>/user/consultations</code>	跳转登录页	☐ 通过 ☐ 不通过
B-04	未登录访问情绪日志页	清空登录状态，访问 <code>/user/emotion</code>	跳转登录页	☐ 通过 ☐ 不通过

3.2 未登录直接访问管理端 API

请求时不携带 `Authorization` 请求头。

编号	接口	方法	预期结果	结果
B-05	<code>/api/knowledge/article/page</code>	GET	拒绝访问或只返回公开文章	☐ 通过 ☐ 不通过
B-06	<code>/api/knowledge/article</code>	POST	拒绝新增文章	☐ 通过 ☐ 不通过
B-07	<code>/api/knowledge/article/{id}/status</code>	PUT	拒绝发布/下线文章	☐ 通过 ☐ 不通过
B-08	<code>/api/knowledge/article/{id}</code>	DELETE	拒绝删除文章	☐ 通过 ☐ 不通过
B-09	<code>/api/psychological-chat/sessions</code>	GET	拒绝访问咨询记录	☐ 通过 ☐ 不通过
B-10	<code>/api/psychological-chat/sessions/{sessionId}/messages</code>	GET	拒绝访问聊天消息	☐ 通过 ☐ 不通过
B-11	<code>/api/emotion-diary/admin/page</code>	GET	拒绝访问后台情绪日志	☐ 通过 ☐ 不通过
B-12	<code>/api/emotion-diary/admin/{id}</code>	DELETE	拒绝删除情绪日志	☐ 通过 ☐ 不通过
B-13	<code>/api/file/upload</code>	POST	拒绝未登录上传或限制业务类型	☐ 通过 ☐ 不通过

3.3 普通用户访问管理员 API

使用普通用户登录后，复制其 `Token`，请求后台管理接口。

编号	接口	方法	测试内容	预期结果	结果
B-14	<code>/api/knowledge/article</code>	POST	普通用户新增知识文章	返回无权限	☐ 通过 ☐ 不通过
B-15	<code>/api/knowledge/article/{id}/status</code>	PUT	普通用户发布/下线文章	返回无权限	☐ 通过 ☐ 不通过
B-16	<code>/api/knowledge/article/{id}</code>	DELETE	普通用户删除文章	返回无权限	☐ 通过 ☐ 不通过
B-17	<code>/api/psychological-chat/sessions</code>	GET	普通用户查看全部咨询会话	返回无权限或仅本人数据	☐ 通过 ☐ 不通过

编号	接口	方法	测试内容	预期结果	结果
B-18	/api/emotion-diary/admin/page	GET	普通用户查看后台情绪日志	返回无权限或仅本人数据	☐ 通过 ☐ 不通过
B-19	/api/emotion-diary/admin/{id}	DELETE	普通用户删除他人情绪日志	返回无权限	☐ 通过 ☐ 不通过

3.4 Token 异常测试

编号	Token 情况	操作步骤	预期结果	结果
B-20	无 Token	不带 Authorization 访问后台接口	返回未登录	☐ 通过 ☐ 不通过
B-21	空 Token	Authorization: Bearer	返回未登录或 Token 无效	☐ 通过 ☐ 不通过
B-22	随机 Token	Authorization: Bearer abc123	返回 Token 无效	☐ 通过 ☐ 不通过
B-23	篡改 Token	修改 JWT 任意一段内容	返回 Token 无效	☐ 通过 ☐ 不通过
B-24	过期 Token	使用旧 Token 请求接口	返回登录过期	☐ 通过 ☐ 不通过
B-25	退出后 Token	退出登录后继续使用旧 Token 请求	应返回无效或过期	☐ 通过 ☐ 不通过

3.5 敏感数据泄露测试

编号	测试项	操作步骤	预期结果	结果
B-26	用户信息泄露	未登录请求用户资料接口	不返回用户隐私信息	☐ 通过 ☐ 不通过
B-27	咨询消息泄露	普通用户请求他人 sessionId 消息	不返回他人消息	☐ 通过 ☐ 不通过
B-28	情绪日志泄露	普通用户请求后台情绪日志分页	不返回全站日志	☐ 通过 ☐ 不通过
B-29	文章管理泄露	未登录请求草稿/下线文章	不返回非公开文章	☐ 通过 ☐ 不通过
B-30	文件越权访问	构造 /api/uploads/... 地址访问非公开文件	非公开文件不应直接暴露	☐ 通过 ☐ 不通过

4. 白盒测试清单

白盒测试需要查看后端代码，重点检查每个 Controller 是否手动调用了 JWT 校验和角色校验逻辑。

4.1 Controller 鉴权覆盖检查

编号	Controller	检查内容	预期结果	结果
W-01	UserController	登录、注册之外的用户信息接口是否校验 Token	已校验	☐ 通过 ☐ 不通过
W-02	KnowledgeController	新增、删除、发布、下线文章是否校验管理员角色	已校验	☐ 通过 ☐ 不通过
W-03	KnowledgeController	文章分页是否区分前台公开查询和后台管理查询	已区分	☐ 通过 ☐ 不通过
W-04	FileController	上传文件是否校验登录状态、文件类型和业务类型	已校验	☐ 通过 ☐ 不通过
W-05	ChatController	咨询会话分页是否仅管理员可访问	已校验	☐ 通过 ☐ 不通过
W-06	ChatController	查询消息详情是否校验 session 归属或管理员角色	已校验	☐ 通过 ☐ 不通过
W-07	EmotionDiaryController	后台分页接口是否仅管理员可访问	已校验	☐ 通过 ☐ 不通过
W-08	EmotionDiaryController	删除日志接口是否仅管理员或本人可删除	已校验	☐ 通过 ☐ 不通过

4.2 JWT 工具类检查

编号	检查项	检查内容	预期结果	结果
W-09	签名密钥	是否使用足够长度的随机密钥	密钥安全，非默认值	☐ 通过 ☐ 不通过
W-10	Token 过期时间	是否设置合理有效期	已设置过期时间	☐ 通过 ☐ 不通过
W-11	签名验证	是否验证 Token 签名	篡改 Token 无法通过	☐ 通过 ☐ 不通过
W-12	用户 ID 解析	是否从 Token 中解析用户 ID	能正确解析	☐ 通过 ☐ 不通过
W-13	角色解析	是否从 Token 或数据库中确认角色	角色可信	☐ 通过 ☐ 不通过
W-14	异常处理	Token 解析异常是否统一返回未登录	不暴露堆栈信息	☐ 通过 ☐ 不通过

4.3 角色权限逻辑检查

编号	检查项	检查内容	预期结果	结果
W-15	管理员接口	是否显式校验 <code>admin</code> 或 <code>super_admin</code>	已校验	☐ 通过 ☐ 不通过
W-16	用户接口	是否校验当前用户只能访问本人数据	已校验	☐ 通过 ☐ 不通过
W-17	删除接口	是否校验权限后再执行删除	已校验	☐ 通过 ☐ 不通过
W-18	更新接口	是否校验权限后再更新状态	已校验	☐ 通过 ☐ 不通过
W-19	文件上传	是否限制普通用户上传业务类型	已限制	☐ 通过 ☐ 不通过
W-20	数据查询	是否过滤 <code>deleted=0</code> 和权限范围	已过滤	☐ 通过 ☐ 不通过

4.4 白盒风险点记录

风险编号	代码位置	风险描述	修复建议	状态
R-01		Controller 未调用 JWT 校验	增加统一拦截器或补充手动校验	☐ 待修复 ☐ 已修复
R-02		只校验登录，未校验角色	增加角色权限判断	☐ 待修复 ☐ 已修复
R-03		根据前端传入 <code>userId</code> 查询数据	改为从 Token 获取当前用户 ID	☐ 待修复 ☐ 已修复
R-04		管理接口返回敏感字段	DTO 过滤敏感字段	☐ 待修复 ☐ 已修复
R-05		上传目录文件可被直接枚举	限制文件访问或使用随机文件名	☐ 待修复 ☐ 已修复

5. 灰盒测试清单

灰盒测试结合前端操作、接口请求、后端日志和数据库结果进行验证，最适合定位“前端拦了但后端没拦”的问题。

5.1 登录与 Token 流程

编号	测试项	操作步骤	验证点	结果
G-01	登录成功 Token 保存	登录普通用户	localStorage 有 Token，接口返回用户角色	☐ 通过 ☐ 不通过
G-02	请求头携带 Token	打开 Network 查看接口	<code>Authorization: Bearer xxx</code> 正确携带	☐ 通过 ☐ 不通过
G-03	清除 Token 后访问接口	删除 localStorage Token 后刷新	前端跳登录页，接口返回未登录	☐ 通过 ☐ 不通过

编号	测试项	操作步骤	验证点	结果
G-04	使用普通用户 Token 调后台接口	Apifox/curl 携带普通用户 Token 请求后台 API	后端拒绝，而不只是前端拒绝	☐ 通过 ☐ 不通过

5.2 管理端接口越权验证

编号	测试场景	操作步骤	数据库/日志验证	预期结果	结果
G-05	普通用户新增文章	携带普通用户 Token POST /api/knowledge/article	查询 knowledge_article 是否新增	不应新增	☐ 通过 ☐ 不通过
G-06	普通用户删除文章	携带普通用户 Token DELETE 文章	查询文章 deleted 字段	不应变为 1	☐ 通过 ☐ 不通过
G-07	普通用户发布文章	携带普通用户 Token PUT 状态	查询文章 status 字段	不应改变	☐ 通过 ☐ 不通过
G-08	普通用户查后台情绪日志	携带普通用户 Token GET 后台分页	查看返回数据是否包含他人日志	不应返回全站数据	☐ 通过 ☐ 不通过
G-09	普通用户查咨询消息	构造他人 sessionId 请求消息	查看是否返回他人消息	不应返回	☐ 通过 ☐ 不通过

5.3 数据库状态验证

编号	测试项	操作步骤	SQL 验证	预期结果	结果
G-10	未授权删除文章	普通用户调用删除接口	SELECT deleted FROM knowledge_article WHERE id=?;	字段不变	☐ 通过 ☐ 不通过
G-11	未授权删除日志	普通用户调用删除情绪日志接口	SELECT deleted FROM emotion_diary WHERE id=?;	字段不变	☐ 通过 ☐ 不通过
G-12	未授权上传文件	未登录上传文件	查询 file_resource 最新记录	不应新增	☐ 通过 ☐ 不通过
G-13	越权读取会话	普通用户请求他人会话	查询 session 所属 userId	接口应拒绝	☐ 通过 ☐ 不通过

6. 前端测试清单

编号	测试项	操作步骤	预期结果	结果
F-01	路由守卫	未登录访问后台路由	跳转登录页	☐ 通过 ☐ 不通过

编号	测试项	操作步骤	预期结果	结果
F-02	普通用户路由限制	普通用户访问后台路由	被重定向	☐ 通过 ☐ 不通过
F-03	管理员路由权限	管理员访问后台路由	正常访问	☐ 通过 ☐ 不通过
F-04	Token 删除同步	手动删除 localStorage Token 后刷新	退出登录状态	☐ 通过 ☐ 不通过
F-05	接口错误提示	Token 无效时请求接口	弹出登录过期或无权限提示	☐ 通过 ☐ 不通过
F-06	Network 检查	打开主要页面查看请求头	管理端接口均携带 Token	☐ 通过 ☐ 不通过

7. 后端测试清单

编号	测试项	操作步骤	预期结果	结果
S-01	所有管理接口鉴权	不带 Token 请求管理接口	全部拒绝	☐ 通过 ☐ 不通过
S-02	角色权限校验	普通用户 Token 请求管理接口	全部拒绝	☐ 通过 ☐ 不通过
S-03	Token 解析异常	篡改 Token 请求接口	返回 Token 无效	☐ 通过 ☐ 不通过
S-04	过期 Token	使用过期 Token 请求接口	返回登录过期	☐ 通过 ☐ 不通过
S-05	数据范围校验	普通用户请求他人资源	返回无权限	☐ 通过 ☐ 不通过
S-06	响应字段过滤	查询用户/日志/咨询记录	不返回密码哈希等敏感字段	☐ 通过 ☐ 不通过

8. 数据库测试清单

编号	测试项	SQL 或操作	预期结果	结果
D-01	用户密码安全	查询 sys_user	不应返回明文密码	☐ 通过 ☐ 不通过
D-02	用户角色字段	查询用户角色	角色值明确且不可由前端随意修改	☐ 通过 ☐ 不通过
D-03	软删除验证	删除文章/日志后查询	deleted=1, 接口不再返回	☐ 通过 ☐ 不通过
D-04	咨询数据归属	查询 session 的 userId	接口需按归属校验	☐ 通过 ☐ 不通过
D-05	文件业务归属	查询 file_resource	文件关联业务类型与上传者	☐ 通过 ☐ 不通过

编号	测试项	SQL 或操作	预期结果	结果
D-06	索引检查	SHOW INDEX FROM ...	常用权限/关联字段有索引	☐ 通过 ☐ 不通过

常用 SQL:

```
SELECT id, username, role, status, deleted
FROM sys_user
LIMIT 20;

SELECT id, title, status, deleted
FROM knowledge_article
ORDER BY updated_at DESC
LIMIT 20;

SELECT id, user_id, session_title
FROM psychological_chat_session
ORDER BY updated_at DESC
LIMIT 20;

SELECT id, session_id, sender_type, content
FROM psychological_chat_message
WHERE session_id = ?;

SELECT id, user_id, dominant_emotion, deleted
FROM emotion_diary
ORDER BY updated_at DESC
LIMIT 20;

SELECT id, original_name, file_url, business_type, uploader_id
FROM file_resource
ORDER BY created_at DESC
LIMIT 20;
```

9. curl 测试模板

9.1 不带 Token 请求管理接口

```
curl -i https://web.lonemonk.xyz/api/emotion-diary/admin/page
```

预期:

```
401 Unauthorized
或 code=-1 / code=401 / msg=未登录
```

9.2 携带普通用户 Token 请求管理接口


```
curl -i \
-H "Authorization: Bearer 普通用户Token" \
https://web.lonemonk.xyz/api/emotion-diary/admin/page
```

预期:

403 Forbidden
或 code=403 / msg=无权限

9.3 携带随机 Token

```
curl -i \
-H "Authorization: Bearer abc123.invalid.token" \
https://web.lonemonk.xyz/api/psychological-chat/sessions
```

预期:

Token 无效, 接口不返回数据

9.4 普通用户尝试删除文章

```
curl -i \
-X DELETE \
-H "Authorization: Bearer 普通用户Token" \
https://web.lonemonk.xyz/api/knowledge/article/1001
```

预期:

无权限, 数据库中 deleted 不变化

10. 高风险接口优先级

优先测试以下接口, 因为它们最容易造成后台数据泄露或数据破坏:

优先级	接口	风险
高	/api/emotion-diary/admin/page	泄露用户情绪日志
高	/api/psychological-chat/sessions	泄露咨询会话

优先级	接口	风险
高	/api/psychological-chat/sessions/{sessionId}/messages	泄露聊天内容
高	/api/knowledge/article/{id} DELETE	非法删除文章
高	/api/knowledge/article/{id}/status	非法发布/下线
中	/api/file/upload	未授权上传文件
中	/api/user/profile	越权查看或修改用户信息
中	/api/knowledge/article/page	泄露草稿或下线文章